

Le grand filtre

Matrice de sécurité de l'IA en entreprise suisse

Mathieu, Survivant de l'IA

2026-06-07

Le grand filtre

Matrice de sécurité de l'IA en entreprise suisse — conformité LPD, secret d'affaires, souveraineté.

Le groupe de gauche évalue la conformité LPD. Le groupe de droite évalue la protection effective du secret d'affaires. Un outil peut satisfaire l'un sans l'autre. Les marqueurs a, b, c renvoient aux conditions en bas de page.

Matrice des verdicts

Outil	Résidence	DPA	No-train	Verdict LPD	CMK / clés	Cloud Act	Verdict secret
ChatGPT perso (Free / Plus)	US	Non	Non	Non conforme	Non	Élevé	Exposé
ChatGPT Team / Enterprise	US (UE option)	Oui	Oui	Conforme (a)	Non	Élevé	Risqué
API OpenAI (+ ZDR)	US	Oui	Oui	Conforme (a)	Non	Élevé	Risqué
Azure OpenAI (CH North)	CH	Oui	Oui	Conforme	Oui (+ HYOK)	Moyen	Bon (b)
AWS Bedrock (Zurich)	CH	Oui	Oui	Conforme	Oui (+ HYOK)	Moyen	Bon (b)
Infomaniak AI (API)	CH	Oui	Oui	Conforme	Chiffrement CH	Nul	Protégé
Self-host (Ollama / on-prem)	CH requis (c)	Sans objet	Oui	Conforme (c)	Total	Nul	Maximal (c)

Légende. Vert = conforme / risque faible. Orange = sous conditions. Rouge = non / risque élevé.

Réalité opérationnelle (par outil)

Outil	Point d'attention
ChatGPT perso	Cauchemar du Shadow IT. Aucun contrôle d'accès.
ChatGPT Team / Enterprise	Faux sentiment de sécurité. Protège de l'entraînement, pas du Cloud Act. SSO strict.
API OpenAI (+ ZDR)	Nécessite un middleware pour filtrer/pseudonymiser avant départ US.
Azure OpenAI (CH North)	Niveau "Bon" suppose HYOK + TEE + exemption de journalisation.
AWS Bedrock (Zurich)	Profil jumeau d'Azure. KMS externalisé + Nitro Enclaves.
Infomaniak AI (API)	Écart possible sur raisonnements complexes vs modèles frontière.
Self-host	Le risque se déplace vers la sécurité interne. Coûts GPU cachés.

Conditions

(a) Transfert vers les États-Unis. "Conforme" seulement si fournisseur certifié Swiss-US DPF (adéquation depuis sept. 2024, à vérifier sur dataprivacyframework.gov/list) **ou** clauses contractuelles types + TIA. Statut DPF d'OpenAI ambigu ; Microsoft certifié.

(b) Niveau “Bon” Azure / Bedrock. Atteint uniquement en empilant clé en HYOK (hors d’atteinte de l’hébergeur), calcul confidentiel (TEE) pour l’inférence, et exemption de journalisation. Sans ces couches, le verdict retombe à “Moyen”.

(c) Self-host. Valable à deux conditions : serveur physiquement en Suisse (matériel propre ou hébergeur suisse type Infomaniak ; un VPS étranger ou un cloud américain fait retomber la résidence et peut réintroduire le Cloud Act par la couche infrastructure), **et** sécurité interne (accès, sauvegardes, durcissement) à la hauteur.

Avertissement

Aide à la décision, pas un avis juridique. La qualification précise des données et la conformité d’un déploiement donné doivent être validées par un conseil juridique spécialisé, en particulier sur le volet FINMA. Les caractéristiques des fournisseurs (résidence, options de chiffrement, statut DPF) évoluent et doivent être vérifiées au moment de la contractualisation.

Dernière révision : 7 juin 2026. Version étendue + glossaire : survivant-ia.ch/outils/le-grand-filtre.